

Enterprise Ransomware Incident Response & Risk Analytics Case Study

Simulated SOC Investigation, Business Risk Assessment & Cybersecurity Resilience Analysis

Case Study Disclaimer

This project is a simulated cybersecurity incident response and business risk analysis case study created for educational, analytical, and portfolio development purposes.

The organization, infrastructure, attack scenario, and operational details presented within this report are hypothetical and designed to demonstrate:

- Cybersecurity risk assessment methodologies
- SIEM-based threat investigation concepts
- Incident response workflows
- Business impact analysis
- Enterprise cybersecurity governance practices

This case study does not represent an actual security breach involving a real organization.

1. Executive Summary

This case study is about what happened to NovaMart Global, a big retail and e-commerce company that operates in North America, Europe and Asia-Pacific. NovaMart Global had a cybersecurity problem. The problem was a ransomware attack that targeted NovaMart Global business systems, including customer transaction platforms, financial operations and internal NovaMart Global company infrastructure. This caused a lot of problems for NovaMart Global. It increased the risk of something happening to NovaMart Global.

The attack started when someone in the finance department of NovaMart Global opened an email attachment. After that the person who did the attack was able to stay inside NovaMart Global systems and started doing things like stealing passwords and moving around to different parts of the NovaMart Global system.

NovaMart Global found out about the attack because of some warnings that came up in their security system. These warnings included some things that were happening with PowerShell people trying to log in many times strange communication going out of the NovaMart Global network and a lot of files being changed. The security team of NovaMart Global used some tools, like Splunk Enterprise and Wazuh to look into what was happening and told the Computer Security Incident Response Team (CSIRT) about it.

Because the attack on NovaMart Global was so big, Could have exposed NovaMart Global company information it was considered a very serious incident. The ransomware attack caused a lot of problems for NovaMart Global, including NovaMart Global services being down it being expensive to fix and people worrying about if NovaMart Global could keep running. There were also concerns about what regulators might say about NovaMart Global.

This report looks at what happened to NovaMart Global from a cybersecurity perspective and a business risk perspective. It analyzes how NovaMart Global found out about the threat, how NovaMart Global responded to the incident how NovaMart Global figured out how much risk was involved how it affected NovaMart business and what NovaMart Global did to make their security better. The report is, about the NovaMart ransomware attack and how NovaMart Global dealt with the cybersecurity problem.

2. Company Overview

Organization Profile

NovaMart Global is a company that sells things in stores and online in North America, Europe and Asia-Pacific. They help people buy things online process payments, manage warehouses and do work for customers all around the world. NovaMart Global has than 15,000 employees and handles millions of customer transactions every year so they need their computers and internet to be working all the time.

The company uses a mix of ways to do things like using the cloud having their own servers and letting people work from home. They need to make sure that their websites, inventory systems, money programs and other important tools are always available and safe. NovaMart Global needs to keep all these things working together.

To keep everything NovaMart Global has a special team that watches for bad people trying to hurt them. This team is called the Security Operations Center or the Security Operations Center team, which is also known as the SOC for short. The Security Operations Center team is always looking for threats responding to incidents.

They use tools to help them including:

- Splunk Enterprise to monitor and analyze events
- Wazuh to watch what is happening on computers
- FortiSIEM to manage events and find threats
- Endpoint Detection & Response solutions to stop things from happening
- Firewall and VPN monitoring systems to keep the bad people out
- Intrusion Detection & Prevention Systems to stop them from getting in networks or computers

NovaMart Global also has a Computer Security Incident Response Team or the Computer Security Incident Response Team, which is also known as the CSIRT that helps when there is a security problem. The Computer Security Incident Response Team figures out what happened stops it from getting worse and makes sure everything is okay again. The Computer Security Incident Response Team is very important to NovaMart Global.

Because NovaMart Global is a company that sells things online they have to worry about people trying to hurt them with ransomware, phishing and other attacks. NovaMart Global also has to follow rules and laws to keep customer information safe. So keeping the company safe, from cyber threats is very important to make sure everything runs smoothly and customers trust NovaMart Global. NovaMart Global and their cybersecurity team work hard to keep everything so customers can keep buying things from NovaMart Global without worrying. NovaMart Global has to be very careful to protect themselves from these threats and keep their customers safe. NovaMart Global is always working to keep their customers safe and secure.

3. Incident Overview

Incident Description

On March 14 2026 NovaMart Global had a problem with a ransomware attack. The ransomware attack targeted the systems that customers use to do things and the internal systems that NovaMart Global uses. It started when someone in the finance department at NovaMart Global opened an email attachment that they should not have opened. This email attachment had code in it and it caused a lot of trouble for NovaMart Global.

After that the person who did this was able to get into the system of NovaMart Global and start looking for accounts to hack into. The security systems of NovaMart Global noticed that someone was trying to get into accounts that they should not have access to. They also saw that someone was using PowerShell in a way that they should not be using it and that people were logging in from places. The ransomware attack was moving from one system to another system at NovaMart Global. It was causing a lot of problems for NovaMart Global.

As the ransomware attack kept going important services stopped working at NovaMart Global. This included the systems that customers use to make transactions at NovaMart Global, the systems that NovaMart Global uses the systems that manage inventory at NovaMart Global and the systems that employees use to work at NovaMart Global. Many computers and file systems were encrypted without permission at NovaMart Global, which caused some services to stop working and made it hard for people to get to the resources they needed at NovaMart Global.

The company NovaMart Global found out about the ransomware attack because of alerts from the security systems of NovaMart Global. The security team at NovaMart Global looked at the logs. Noticed some suspicious activity. They used tools like Splunk Enterprise and Wazuh and FortiSIEM to monitor the systems of NovaMart Global and figure out what was going on with the ransomware attack. Because the ransomware attack was so severe they told the Computer Security Incident Response Team to take a look and try to stop the ransomware attack.

When they first looked into the ransomware attack they thought that the people who did this wanted to stop NovaMart Global from working and encrypt systems of NovaMart Global and get NovaMart Global to pay them in cryptocurrency. The ransomware attack caused a lot of problems for NovaMart Global, including problems with how NovaMart Global works, money problems for NovaMart Global problems with the reputation of NovaMart Global and problems with following the rules at NovaMart Global. NovaMart Global had to work to respond to the ransomware attack and try to recover quickly as possible from the ransomware attack.

Because the ransomware attack was so bad and could have exposed information of NovaMart Global, NovaMart Global said it was a Priority 1 Critical Security Incident. This means that it was very important for NovaMart Global and they had to deal with it away. NovaMart Global had to follow their incident response and risk management framework to try to fix the problems caused by the ransomware attack, on NovaMart Global.

4. Initial Detection & Security Monitoring

SIEM-Based Threat Detection

The people at NovaMart Global found out about the ransomware problem when they saw some alerts that were connected. These alerts came from the companys security system. The security team was keeping an eye on things. They saw some weird things happening that made them think someone might be getting into the companys computer system.

The security people looked closely at what was going on and they saw some strange patterns. They used some tools like Splunk Enterprise, Wazuh and FortiSIEM to look at the logs and see how the computers were behaving. The alerts showed them that some computers were acting suspiciously. There were some login attempts someone was using PowerShell when they should not have been and some computers were sending out weird messages to the internet. All of this was happening on computers that the finance department used. The ransomware incident was a deal and NovaMart Globals security team had to take a closer look, at the finance departments computers.

Initial Indicators of Compromise (IOCs)

During the early stages of investigation, the SOC team identified several Indicators of Compromise (IOCs) associated with ransomware-related activity, including:

Security Indicator	Observed Activity	Potential Risk
Unauthorized PowerShell Execution	Suspicious command-line execution from employee endpoint	Malware execution
Repeated Authentication Failures	Multiple failed login attempts across privileged accounts	Credential compromise
Privilege Escalation Attempts	Unauthorized administrative access requests	Elevated attacker access
Suspicious Outbound Connections	Communication with unknown external IP addresses	Command-and-control activity
High-Volume File Modification	Rapid file encryption behavior on shared systems	Ransomware deployment
Lateral Movement Activity	Remote authentication attempts between internal servers	Enterprise-wide propagation

When we looked at these security events we saw that they were connected. This connection made it more likely that something bad was happening with the security of our company. So we started looking into it away using special procedures in the place where we monitor security. We call this place the SOC environment. The security events and the SOC environment are very important. The security events made us think that the SOC environment needed to do something. The security events and the SOC environment are connected.

Security Monitoring & Log Analysis

The security team starting looking into the incident to find out what was going on. They needed to know what was happening and how bad it was. In order to do this the team had to comb through all the following:

- Windows event logs
- Firewall & VPN Logs
- Alerts from the computer problem detector system
- Logs that were tracking what users were doing when they did it.
- Logs that were tracking the traffic on the network.
- Security information system events correlated together.

After reviewing the logs, some of the activities that the users and the administrators were doing raised some concerns. It was realized that someone was trying to gain unauthorized access from the outside. It was also realized that there was traffic between computers in the internal network, which was unusual and not normal.

The security team was worried about the security incident. It needed to do something about it. It had to work together with the security operation center and the security team to analyze the security incident. The security team identified the connection of the security incident to the security operation center and the security team. The security team and the security operation center worked together on the security incident in order to overcome the problem and come to a solution. The security team identified what the security operation center was doing to address the security incident. The security incident was a problem that had to be overcome and the security team was making all efforts to make it happen.

Incident Escalation Workflow

Following the escalation, due to the severity of events and expanded range of suspicious activity detected, the activity shifted from regular SOC monitoring activities to a Computer Security Incident Response Team (CSIRT) for rapid containment and forensics.

The escalation process was as follows:

1. SOC validated the alert and performed a triage
2. Threat severity assessed
3. Enterprise-wide security events were correlated
4. The endpoint was determined to be compromised
5. The incident classification was reviewed
6. Executives were notified and the CSIRT was activated

Due to the potential operational effect and the possibility of widespread infection of the entire enterprise, the event was declared as a high-level security incident requiring swift response coordination and containment.

Challenges encountered during the detection stage:

The SOC team encountered many operational challenges while attempting to detect the event, including:

1. High quantity of logs within the enterprise
2. High levels of false positives within alert system
3. A lack of visibility into outgoing encrypted traffic
4. High degree of lateral movement throughout internal systems
5. Time constraints regarding the immediate containment of the activity

The SOC team's ability to identify the ransomware before total system encryption across the enterprise was partially due to the organized monitoring of centralized SIEM and efficient SOC operations.

5. Incident Classification & Severity Assessment

The classification was attributed as a result of the organizations incident response plan, severity identification process and overall effects on business critical systems and enterprise level operation. The incident exhibited many of the hallmarks of a high impact ransomware campaign, capable of substantial operational and financial damage as well as enterprise level compromise.

Multiple Priority 1 escalation requirements were identified for the attack as a result of the:

- Active disruption of customer facing services
- The likelihood of compromise to enterprise sensitive information
- Enterprise wide impact on operations
- Elevated exposure of risk (financial and reputational)
- Increased possibility of a regulatory/compliance issue
- Concerns about business continuity

Incident Classification

Following initial investigation and threat validation procedures, the ransomware attack was formally classified as a:

Priority 1 — Critical Security Incident

Severity Assessment Process

The security incident severity assessment was performed by the SOC with support from the CSIRT. Analysts reviewed the incident based on the following risk based assessment factors:

- Extent of system compromise
- Criticality of systems affected
- Business impact on operations
- Risk of data exfiltration
- Risk of system downtime
- Threat actor persistence and activity
- Risk of horizontal propagation and ransomware spreading

After combining both the technical impact and business impact, the incident severity level was upgraded from a suspicious event to a critical enterprise security incident requiring containment and executive coordination.

Factors Contributing to Critical Severity Classification

Several technical and operational indicators contributed to the critical severity assessment of the ransomware incident.

1. Business-Critical System Impact

The attack affected various enterprise systems which are the back bone of a business in its everyday operations and they were:

- Customer transaction systems;
- Financial processing applications;
- Inventory systems;
- Shared file systems;
- Enterprise collaboration applications.

Because these systems were disrupted the enterprise's operations became increasingly unstable.

2. Evidence of Advanced Threat Activity

Investigation findings identified multiple indicators associated with advanced ransomware operations, including:

- Unauthorized PowerShell execution
- Credential harvesting activity
- Privilege escalation attempts
- Lateral movement across internal systems
- Suspicious external communications
- Coordinated file encryption behavior

These indicators suggested a well-structured attack campaign with the potential to expand rapidly across enterprise infrastructure.

3. Elevated Business Risk Exposure

The incident introduced substantial enterprise risk across multiple categories:

Risk Category	Impact Level	Description
Operational Risk	Critical	Disruption of customer and internal operations
Financial Risk	Critical	Revenue loss, recovery expenses, downtime costs
Reputational Risk	High	Customer trust and brand reputation concerns
Compliance Risk	High	Potential regulatory and legal obligations
Data Security Risk	Critical	Possible exposure of enterprise information
Business Continuity Risk	Critical	Risk of prolonged service interruption

The combined impact across operational and business functions significantly increased overall organizational risk exposure.

Incident Escalation & Response Coordination

Given the nature of the incident, it was automatically elevated as per the enterprise incident response policy. Coordination was put in place across:

- Security Operations Center (SOC)
- Computer Security Incident Response Team (CSIRT)

- Network Security Teams
- Infrastructure & Server Operations
- Legal & Compliance Teams
- Executive Leadership
- Business Continuity Stakeholders

The entity initiated the accelerated containment and response process to limit further ransomware transmission and to minimize operational interruption.

Operational Challenges During Severity Assessment

Within the classification and evaluation phase, several problems arose which hindered swift analysis of incidents:

- Large volumes of enterprise security events
- High alert correlation complexity
- Limited visibility into encrypted communications
- Rapid expansion of lateral movement activity
- Time-sensitive containment requirements
- Dependency on interconnected enterprise systems

The centralized SIEM monitoring and synchronized incident response workflow, however, allowed the organization to quickly assess the magnitude of the ransomware campaign and begin to contain it across the entire enterprise.

Executive Risk Perspective

From an executive risk management perspective, the incident demonstrated how a technical security event-a ransomware attack-can very quickly transform into a business risk event at an enterprise level. The analysis of the incident revealed the necessity of:

- Continuous security monitoring
- Rapid incident escalation procedures
- Cross-functional response coordination
- Business continuity planning
- Risk-based cybersecurity governance
- Executive-level cybersecurity decision-making

This further reinforced the need for better enterprise resilience frameworks capable of minimizing operational impact and strengthening organizational preparedness to catastrophic cyber events.

6. Risk Assessment & Business Impact Analysis

Risk Assessment Overview

After initial incident response and forensic investigation, NovaMart Global engaged in a comprehensive business risk assessment to determine the operational, financial, technical, and strategic risks associated with the ransomware attack. It was important to conduct this to identify critical business risks, measure exposure, understand prioritization during recovery, and assist in future long term cybersecurity resilience planning.

The scope of the analysis revolved around the extent of the impact of the ransomware incident on the enterprise operations, customer visible services, underlying enterprise systems, and business continuity operations, as well as review of the efficacy of existing security controls, monitoring capabilities, incident response procedures and enterprise risk management framework.

The risk assessment process included:

- Identification of business-critical assets
- Threat and vulnerability analysis
- Operational impact evaluation
- Likelihood and severity assessment
- Risk prioritization and scoring
- Business continuity impact analysis
- Strategic mitigation planning

6.1 Critical Asset Identification

A few critical business systems were compromised in the ransomware attack. These systems are of utmost importance for the functioning of the enterprise and in providing customer service. The following assets were highlighted during the assessment as critical business systems:

Critical Asset	Business Function	Risk Level
Customer Payment Systems	Revenue generation and transaction processing	Critical
E-Commerce Platform	Customer operations and online sales	Critical
Financial Applications	Enterprise financial management	Critical
Inventory Management Systems	Supply chain and logistics coordination	High
Active Directory Infrastructure	Enterprise authentication and access management	High
Employee Endpoints	Daily operational activities	High
Shared File Servers	Internal document storage and collaboration	High
SIEM Infrastructure	Security monitoring and threat visibility	Medium

The highest priority assets identified in the assessment were the customer transaction system and financial applications as these are most closely linked to the revenue of the business and business continuity.

6.2 Threat Identification & Analysis

Multiple threats were observed in the ransomware campaign the investigation has uncovered. The security team analyzed attacker's behavior, attack process and effects to quantify extent and seriousness of exposure of the enterprise to risks.

Threat Category	Description	Potential Business Impact
Ransomware Deployment	Encryption of enterprise systems and files	Operational shutdown
Phishing-Based Initial Access	Malicious email attachment execution	Credential compromise
Privilege Escalation	Unauthorized administrative access	Enterprise-wide compromise
Lateral Movement	Internal propagation across systems	Expanded operational disruption
Credential Harvesting	Theft of user credentials	Unauthorized access risk
Data Exfiltration	Potential theft of enterprise information	Compliance and reputational impact
Persistence Mechanisms	Continued attacker access within environment	Re-infection and long-term compromise

It was observed in the analysis that attackers used several attack methods to maximize the disruption on the business and add pressure on the organization for payment..

6.3 Vulnerability Assessment

The findings of the incident investigation revealed various security weaknesses and operational shortfalls, which led to increased organizational exposure to ransomware events.

Identified Vulnerability	Associated Risk
Limited advanced email filtering controls	Increased phishing success probability
Inadequate endpoint visibility	Delayed threat detection
Weak privileged access management	Elevated lateral movement risk
Insufficient employee security awareness	Increased social engineering exposure
Delayed patch management processes	Exploitable vulnerabilities within enterprise systems
Limited network segmentation	Faster ransomware propagation across systems
High dependency on interconnected infrastructure	Increased operational disruption impact

The findings pointed to the need for enhancement of proactive security controls, improving monitoring on endpoints and bolstering employees' cyber security awareness training.

6.4 Likelihood Assessment

Security analysts assessed the likelihood that identified threat scenarios would reoccur, based on observed attack behaviors, current security posture, and industry threat intelligence.

Threat Scenario	Likelihood Level
Phishing-Based Attacks	High
Credential Compromise	High
Privilege Escalation Activity	High
Data Exfiltration Attempts	Medium to High
Ransomware Propagation	Critical
Business Service Disruption	Critical
Insider-Assisted Threat Activity	Medium

The probability analysis predicted that phishing-driven ransomware threats pose one of the greatest enterprise cybersecurity threats to operational continuity and business resilience.

6.5 Business Impact Analysis

The ransomware attack had significant operational, financial, reputational and compliance effects throughout the organization.

Operational Impact

Business Function	Operational Impact
Online Retail Services	Service disruption and transaction delays
Warehouse Logistics	Delayed inventory processing
Financial Operations	Payment processing interruptions
Internal Collaboration Systems	Restricted employee communication
Customer Support Services	Reduced operational availability

Operational disruption affected the organization's ability to carry on its normal business functions and to maintain continuity of customer services.

Financial Impact

Financial Risk Area	Estimated Impact
Revenue Loss from Downtime	High
Incident Response Expenses	High

System Recovery Costs	High
Business Interruption Costs	Medium to High
Potential Regulatory Penalties	Medium
Infrastructure Restoration Costs	High

The financial evaluation pointed to the losses associated with downtime and recovery activities as being the primary and immediate financial threat to the organization.

Reputational Impact

Reputational Risk Area	Impact Level
Customer Trust	High
Brand Reputation	High
Stakeholder Confidence	Medium to High
Public Perception of Security Posture	High

This event has a potential for heightening customer concerns over data protection and enterprise cybersecurity resiliency.

Compliance & Legal Impact

Compliance Area	Risk Level
Customer Data Protection Obligations	High
Breach Notification Requirements	High
Legal Investigation Exposure	Medium
Regulatory Review & Audit Risk	Medium to High

The organization commenced its legal and compliance review process to establish reporting obligations and assess regulatory risks related to the event.

6.6 Risk Scoring Matrix

Risk Scenario	Likelihood	Business Impact	Overall Risk Level
Enterprise Ransomware Propagation	Critical	Critical	Critical
Data Theft & Exposure	High	Critical	Critical
Operational Service Downtime	Critical	High	Critical
Privileged Account Compromise	High	High	High
Phishing Recurrence	High	Medium	High

Compliance Violations	Medium	High	Medium to High
-----------------------	--------	------	----------------

The company has adopted a risk assessment methodology based on likelihood and business impact, in order to evaluate and rank the enterprise cybersecurity risks.

The risk scoring process allowed leadership to assign a priority level to their containment, recovery, and long-term mitigation actions based on severity in terms of Enterprise Impact.

6.7 Risk Prioritization

Based on the overall assessment findings, the organization established the following risk response priorities:

Immediate Priorities

- Contain ransomware propagation
- Isolate compromised systems
- Disable affected user accounts
- Protect backup infrastructure
- Restore customer-facing services

Short-Term Priorities

- Conduct forensic investigation
- Validate system integrity
- Restore business-critical applications
- Improve detection visibility
- Strengthen access control monitoring

Long-Term Priorities

- Enhance phishing defense capabilities
- Improve network segmentation
- Strengthen privileged access management
- Expand SIEM correlation and detection rules
- Increase employee cybersecurity awareness
- Improve business continuity resilience planning

6.8 Strategic Risk Mitigation Recommendations

The assessment identified several strategic recommendations designed to reduce enterprise cybersecurity risk and improve resilience against future ransomware incidents.

Recommendation	Security Objective
Multi-Factor Authentication (MFA)	Reduce credential compromise risk
Enhanced SIEM Correlation Rules	Improve early threat detection
Endpoint Detection & Response Expansion	Strengthen endpoint visibility
Network Segmentation	Limit ransomware propagation
Security Awareness Training	Reduce phishing success rates
Backup Isolation & Recovery Testing	Improve operational resilience
Threat Hunting Program	Identify hidden attacker activity
Zero Trust Security Implementation	Strengthen enterprise access control

The group decided that sustained resilience to cyber threats could only be achieved by bringing security operations into better alignment with business continuity plans, executive risk management, and enterprise security governance strategies.

7. CSIRT Response & Incident Workflow

7.1 CSIRT Activation & Incident Escalation

Upon the confirmation of suspicious security activity and validation of indicators suggesting the use of ransomware, the SOC began the incident escalation process according to the NovaMart Global Incident Response Plan.

The incident was escalated to the Computer Security Incident Response Team (CSIRT) based on the following criteria:

- Escalating range of compromise
- Growing indication of ransomware propagation
- Indications of the compromise of elevated privileges
- Operational downtime and the impact on business-critical systems
- Growing level of enterprise risk

Upon activation, the CSIRT launched a response in coordination with the following departments:

- SOC Analysts
- Network security team
- Infrastructure and server operations
- Legal and compliance teams
- Executive leadership
- Business continuity stakeholders

The monitoring and validation phase of the incident response process was replaced by activities of incident containment and coordinated enterprise response operations.

7.2 Incident Investigation Workflow

Once the incident was escalated the CSIRT followed a standardized incident investigation methodology to understand the scope, the severity and the business impact of the ransomware infection.

The investigation procedure that the team followed contained the following steps:

1. Validate SIEM triggered alerts,
2. Identify affected systems and accounts,
3. Monitor abnormal authentication attempts,
4. Review Powershell execution logs,
5. Monitor lateral movement,
6. Correlate network traffic anomalies,
7. Investigate endpoint compromise,
8. Monitor encryption of data.

Security analysts leveraged enterprise-wide SIEM monitoring technologies such as Splunk Enterprise, Wazuh, and FortiSIEM to gather enterprise security events and correlate activity to establish a pattern of the attack progression.

The investigation found evidence of:

- Unauthorized attempts to gain privileged access,
- Credential harvesting activity,
- Suspicious outbound connections,
- Lateral movement within the enterprise, and
- Bulk encryption.

Analysis and threat intelligence determined that the operational activity associated with the ransomware infection mimicked best practices of ransomware operational methodology, which has been known to cause maximum business disruption and pressure the victims into paying ransom.

7.3 Containment Actions

Once confirmed active ransomware is detected the CSIRT immediately began the containment phase to limit the spread of the ransomware through enterprise systems.

The first and main steps undertaken to contain the incident were:

- Isolated compromised endpoints from the enterprise network
- Disabled compromised user and administrator accounts and credentials
- Black listed any external suspect IP address or domains
- Limited remote access functionality.
- Segmented compromised infrastructure
- Temporarily turned off compromised shared file services
- Implemented emergency firewall rules, strengthened SIEM monitoring for further IoC detection throughout the enterprise system.
- Utilized EDR technology for both isolating and monitoring malicious activity from compromised endpoints during the containment.

As the enterprises networks are complex to isolate each action in the containment process is prioritized based on the:

- Criticality of business systems
- Operational dependency,
- Risk of spread,
- Customer impact,
- Recoverability complexities.

The containment stage in the enterprise network has drastically reduced the impact of total encryption and allowed the vital operational systems needed for recovery to be protected.

7.4 Eradication & Recovery Process

Once the environment was stabilized following containment, eradication and recovery operations began to remove malicious artifacts and restore affected systems and services. Eradication actions included; malicious files and persistence mechanisms, credential reset for compromised accounts, malware signature and IOC validation, endpoint reimaging, system cleanup, patch validation and vulnerability remediation, backup integrity checks. Recovery actions included restoring; customer transaction systems, financial applications, inventory systems, enterprise authentication, internal communication infrastructure, etc. The organization's isolated backup infrastructure was used to restore compromised systems. Forensic validation was also completed to ensure all ransomware persistence mechanisms were removed from endpoints prior to reconnecting them to production. Ongoing monitoring activities were completed to detect any reinfection indicators during the recovery phase.

7.5 Communication and Stakeholder Coordination

The CSIRT utilized controlled communication pathways throughout the incident response lifecycle to effectively coordinate efforts between executive leadership, security operations, IT infrastructure, legal and compliance, business continuity and customer support operations. Executive leadership received constant situation reports concerning the incident severity, operational impact, recovery progress, business continuity risks, regulatory issues, and potential service recovery timelines. Legal and compliance teams provided guidance concerning potential data exposures, regulatory notification and customer communication obligations and external reporting requirements. Controlled internal communication also helped to minimize misinformation and ensure overall operational coordination across the enterprise.

7.6 Business Continuity & Recovery Support

The ransomware attack forced the disruption of normal business processes, therefore NovaMart Global implemented business continuity procedures in order to guarantee business critical enterprise operations could continue throughout the recovery efforts.

The objective of business continuity initiatives were to:

- Protect core customer services
- Protect core operational processes
- Minimize business process impact
- Protect workforce continuity
- Protect customer transaction capabilities
- Protect revenue streams

The decisions on prioritizing the recovery effort were based on:

- Business critical nature of the service

- Impact of the service on the customer's business processes
- The financial risk exposures involved
- Regulatory compliance requirements
- Difficulty and resource requirements of recovering infrastructure components

This incident reinforces the need to integrate cybersecurity operations with enterprise business continuity planning, operational resilience efforts, and enterprise risk management execution.

Lessons identified as a result of the post incident review were that, it is imperative to implement:

- Quickened incident response coordination
- Improve Ransomware resiliency strategy
- Ensure backup segregation measures
- Strengthen Privileged access management controls
- Broader employee security awareness
- Develop enhanced threat detection & response controls

The organized incident response shows NovaMart's capability in executing enterprise wide cyber incident response while continuing focus on operational recovery and long-term enterprise resiliency.

8. Cyber Kill Chain Analysis



8.1 Reconnaissance

In the first stage of the attack life cycle, the threat actor carried out reconnaissance tasks, looking for ways to carry out their attack against NovaMart Global's enterprise environment. Attackers probably targeted individuals by using social engineering, attempting to exploit a human flaw and gain an initial foothold into NovaMart Global's environment. The attackers more than likely utilized publicly available information, information about how employees communicate and conduct business related emails to try to gain a better success rate for their phishing attempts.

This stage also showed the need for:

- Security awareness training
- Email security
- Threat intelligence monitoring
- External attack surface monitoring

8.2 Initial Access

The initial infection for the ransomware campaign was established via a phishing attack in the form of a malicious invoice which was opened by an employee in the finance department. When the malicious file was run, the attacker was able to gain initial access into the enterprise environment and security monitoring then noticed unusual PowerShell commands being executed, indicative of the execution of unauthorized code and malware deployment.

This successful phishing attack exploited the following areas:

- Email filtering capability
- Employee phishing awareness

- Endpoint protection capability
- Initial malware detection

8.3 Execution

After gaining initial access the threat actor executed malicious scripts and ransomware related payloads on the compromised machine.

Security analysts observed the following in the environment:

- Malicious use of PowerShell,
- Suspicious process generation,
- Scripted malware,
- Endpoint execution,

These activities provided the attacker with the capabilities to start credential harvesting, deploy malware, and develop the enterprise environment in order to deploy ransomware across systems.

The execution phase highlights the importance of:

- Endpoint visibility,
- Behavioral threat detection,
- PowerShell log visibility,
- Application control

8.4 Persistence

Once the malicious code execution was confirmed, an attacker would create persistence mechanism in order to gain ongoing access in enterprise environment.

Investigation identified that some methods used was:

- Scheduled tasks
- Registry manipulation
- Credential reuse
- Endpoint changes related to persistence

The persistence mechanisms added the attacker to maintain long-term access, and continue its actions even if some containments were started.

The relevant items were:

- Constant monitoring of endpoints
- Detection of persistence mechanisms
- Threat Hunting activities
- Audit of security settings

8.5 Privilege Escalation

Attacker focused on exploiting enterprise environment privilege escalation attacks toward administrative credentials and privileged accounts.

Security monitoring systems observed:

- Unauthorized administrative credential usage;
- Abnormal administrative authentication patterns;
- Unusual account privilege modification activities;
- Indicative signs of high-level account abuse;

Privilege escalation assisted the attacker to acquire an expanded access within the enterprise infrastructure and amplify their effectiveness on ransomware activity. Incident highlights:

- Privileged Access Management (PAM);
- Multi-Factor Authentication (MFA);
- Least privilege policy application;
- Administrative action monitoring.

8.6 Lateral Movement

Upon successfully escalating privilege, the threat actor began to perform lateral movement throughout internal infrastructure.

Security team actions identified:

- Multiple instances of internal remote authentication attempts
- Unexpected intra-network communications
- Instances of authentication between enterprise servers
- Indicators of enterprise shared file infrastructure compromise

Lateral movement vastly expanded the reach of the ransomware attack and increased the compromised internal estate.

Key controls and observations for this phase included:

- Segmentation of internal network segments
- Monitoring of all internal traffic
- East-west network traffic monitoring
- Zero Trust implementation

8.7 Command & Control

An analyst, during the investigation process, detected the unusual outgoing network communication that was suggestive of Command and Control activity.

These indicators included:

- Unknown IP addresses on the outside
- Unusual traffic out of the enterprise network
- Encrypted traffic
- Repeated external connections attempted

The command and control stage allowed the adversaries to remotely orchestrate their actions, issue orders and possibly exfiltrate enterprise data before the deployment of the ransomware.

The areas identified to be of importance during this stage were:

- DNS monitoring
- Network Traffic Analysis
- Threat Intelligence analysis

- Filtering outbound traffic

8.8 Actions on Objectives

The concluding phase of the attack consisted of an extensive use of ransomware payloads to encrypt critical business systems and disable the enterprise operations.

Critical business systems affected by the ransomware are the following ones:

- Business transaction platform
- Finance applications
- Shared enterprise file systems
- Inventory management systems

The ransomware activity lead to:

- Business disruption
- Reduced system access
- System downtime
- Business continuity impact
- Financial and reputational risks

Ultimately the attackers tried to force the organization to pay a ransom using cryptocurrencies.

8.9 Kill Chain Analysis Summary

The Cyber Kill Chain analysis revealed how the ransomware attack unfolded through multiple, coordinated attack stages, starting with the initial foothold via phishing to end with full-scale disruption of the entire business.

The attack exposed numerous security weaknesses such as:

- A lack of phishing resilience
- A lack of endpoint visibility
- Poor controls over privileged access
- A lack of network segmentation

The analysis also highlighted the need to combine the following into an operation:

- SIEM based security monitoring,
- Endpoint detection
- Threat intelligence
- Incident response, and
- Risk based security.

The attackers progression through the Cyber Kill Chain allowed NovaMart Global to identify deficiencies in their security defenses and, in turn, increase their security threat detection and business security resilience against subsequent ransomware attacks.

8.10 MITRE ATT&CK Mapping

In order to better understand the methods used in a ransomware attack, the activities were mapped against the MITRE Corporation ATT&CK framework in order to determine the tactics and techniques employed by the adversary.

Attack Activity	MITRE Technique	MITRE ID
Phishing Email Delivery	Phishing	T1566
PowerShell Execution	Command and Scripting Interpreter: PowerShell	T1059.001
Credential Harvesting	Credential Dumping	T1003
Privilege Escalation	Exploitation for Privilege Escalation	T1068
Lateral Movement	Remote Services	T1021
Command & Control Communication	Application Layer Protocol	T1071
Data Encryption	Data Encrypted for Impact	T1486

The MITRE ATT&CK mapping enabled further visibility on attack patterns and ensured alignment of the incident analysis with industry-recognized threat modeling approaches. Moreover, the framework aided in better understanding of:

- Attack progression
- Detection options
- Defense control deficiencies
- Threat monitoring needs for the enterprise

In this regard, mapping the incident to MITRE ATT&CK framework contributed significantly towards improving the company's ability to enhance threat detection tactics and incident response planning.

9. Risk Mitigation Recommendations

9.1 Security Monitoring Improvements

This event points to an urgent need to better provide visibility of threats across the enterprise and improve monitoring using SIEM. To improve early threat detection and speed up response, NovaMart Global needs to enhance their central monitoring of business-critical infrastructure and systems.

Specific improvements recommended for the monitoring include:

- Additional SIEM correlation rules targeting ransomware indicators
- Increased visibility over PowerShell and endpoint logging
- Integrating threat intelligence feeds into the SIEM process
- Automated prioritization and risk assessment of alerts
- Persistent monitoring over privileged accounts
- Increased detection coverage over lateral movement behavior

Proactive threat hunting needs to be incorporated to discover suspicious behavior prior to impacting the business.

9.2 Endpoint & Infrastructure Security Enhancements

The ransomware attack highlighted weaknesses in endpoint security measures and enterprise hardening processes.

Some recommended steps are:

- Increase endpoint detection and response (EDR) deployment
- Implement whitelisting of authorized applications
- Regular patch management and remediation of vulnerabilities
- Endpoint behavioral monitoring capability
- Prevent execution of unauthorized PowerShell code
- Harden systems configuration of enterprise assets

Assess critical systems for vulnerability and configurations continuously in order to decrease the attacking surfaces.

9.3 Identity & Access Management Improvements

During the incident, Privilege Escalation was detected which revealed the vulnerabilities in the Identity & Access controls of the enterprise.

Below are some recommended enhancement to improve this controls:

- Implementing Enterprise Wide Multi Factor Authentication(MFA)
- Privileged Access Management (PAM)
- Implementing Least Privilege Access
- Continuous Monitoring on Privileged Accounts

- Performing regular access reviews
- Using Conditional access and Zero Trust for authentication controls

Implementing strong Identity security measures would minimize the risks related to unauthorized administrative access and lateral movement.

9.4 Network Security Recommendations

The lateral movement strategy utilized was an internal process which provided greater operational scope through internal networks, expanding the affected domain.

NovaMart Global could mitigate propagation risk by enforcing:

- Network segmentation;
- monitoring East-West network traffic;
- Detection of anomalous internal network activity;
- Rule enforcement on firewalls;
- Monitoring remote connections; and
- Isolation measures for business critical services.

Monitoring of all outbound network connections should also be tightened to ensure malicious command and control signals are not being broadcast nor that sensitive data is being transmitted without authorization.

9.5 Employee Awareness & Security Culture

Since the attack leveraged a phishing-based initial access vector, employees' security awareness is an important defense layer to the organization. The following actions should be taken:

- Phishing simulation drills on a regular basis.
- Security awareness training sessions.
- Education on social engineering attacks.
- Awareness on incident reporting.
- Procedures on handling emails securely.
- Training on security for relevant employees depending on roles.

A positive security culture helps in making social engineering and phishing attempts less successful.

9.6 Incident Response & Business Continuity Improvements

Recovery efforts

Suggested improvements are:

- Periodic CSIRT simulations
- Revising incident response playbooks
- Automating response activities (containment)
- Testing business continuity

- Validating isolated backups & recovery
- Rapid executive escalation
- Periodic ransomware readiness assessment: the organization should periodically assess how well it would be able to recover.

9.7 Strategic Security Governance Recommendations

Sustainable cyber security resilience over time will depend on an organizations' ability to ensure security operations is aligned with the enterprises' governance, and business risk management approaches.

There are strategic recommendations that include:

- Compliance with the NIST Cyber Security Framework
- Risk-based cybersecurity governance within the enterprise
- Cyber risk reporting at an executive level
- Ongoing cybersecurity maturity assessments
- Security risk assessments on third party dependencies
- Regulatory readiness assessments

Cyber security needs to be an integral part of an enterprises' business decisions and business continuity efforts.

9.8 Long-Term Cybersecurity Resilience Strategy

The ransomware attack illustrates that today's threats can quickly become an enterprise-wide operational risk and business risk event. To achieve long-term resilience, NovaMart Global needs to invest in:

- Zero trust security architectures
- AI-powered detection capabilities
- Enhanced behavioral analytics
- Ongoing threat intelligence incorporation
- Active threat hunting program
- Enterprise-wide cyber resilience planning

The business needs to move away from reactive security operations towards a proactive, risk-based cybersecurity approach capable of enhancing operational resilience, mitigating business disruption and improving enterprise-wide security posture against contemporary ransomware attacks.

10. Lessons Learned

10.1 Security Monitoring Lessons

This ransomware attack has underscored the importance of a centralized SIEM monitoring facility, quick alert correlation and forward-thinking threat detection abilities in enterprise settings. The company correctly noticed the anomaly on the SIEM with the provided alerts, but while examining the incident they have recognized the ability to:

- Detect malicious behavior in real-time
- Gain better visibility into the endpoint,
- Monitor PowerShell processes,
- Monitor lateral movement in the environment, and
- Automatically prioritize alerts for immediate investigation.

The incident has identified areas where a deeper correlation between the SIEM monitoring, endpoint telemetry and threat intelligence operations needs to be established to allow detection at an early stage of an attack.

10.2 Incident Response Lessons

The incident demonstrated the need for efficient incident response workflows and tight cross-function cooperation in enterprise security incident scenarios. Lessons learned from this event were:

- The speed of escalation greatly impact the effectiveness of containment efforts;
- Clearly defined roles and responsibilities of CSIRT members decrease operational delay;
- The implementation of automated containment measures can significantly minimize the spread of ransomware;
- Regular incident response simulations enhance operational preparedness;
- The use of centralized communication channels is an effective way to facilitate coordination among members;

The organization realized the benefit of updating incident response playbooks in accordance with current ransomware attack vectors.

10.3 Business Continuity Lessons

The ransomware attack illustrated the speed at which the operational integrity and business continuity operations of an enterprise could be jeopardized. The operational impacts in terms of customer transaction processing, financial systems, and collaborative workflow applications emphasized the need for:

- Recovery prioritization planning
- An isolated backup infrastructure
- Business continuity testing
- Operational resilience
- The mapping of critical service dependencies

The organization recognizes the need for better linkage of cybersecurity operations with business continuity planning.

10.4 Access Control & Identity Lessons

Privilege escalation activity during the incident identified gaps in identity and access management controls.

The organization has determined multiple opportunities for improvement, to include:

- Robust Privileged Access Management (PAM)
- Enterprise wide Multi-Factor Authentication (MFA)
- Continuous monitoring of administrative accounts
- Enforcement of the least privilege concept
- Accelerated identification of credential compromise

The incident served as a reminder that Identity Security is essential to overall enterprise cyber resilience.

10.5 Human Risk & Awareness Lessons

As the initial access was via a phishing-based vector, the organization acknowledges that human error is one of the major risks to the cybersecurity of an enterprise. The event identified that it is necessary to increase levels of:

- Regular phishing awareness training
- Employee education regarding security practices
- Awareness of handling e-mails securely
- Simulations of social engineering attacks
- An organization culture of prompt and internal incident reporting.

In conclusion, technical controls are insufficient on their own without appropriate levels of employee awareness.

10.6 Strategic Risk Management Lessons

The ransomware attack clearly illustrated that cyber threats need to be viewed not just as a technical risk, but as an enterprise business risk impacting:

- Revenues and revenue streams;
- Business continuity;
- Customer confidence;
- Regulatory and compliance requirements;
- Brand reputation and organizational standing.

The importance of embedding cybersecurity risk management into executive-level decisions, business continuity and enterprise governance frameworks was now understood.

The incident also reinforced the necessity for:

- Risk based approach to security prioritization;
- On-going assessments of security maturity;
- Reporting of cyber risks to executives.
- Enterprises' resilience planning

10.7 Overall Organizational Learning

The ransomware attack taught NovaMart Global an important lesson; cyber threats evolve into strategic business problems and operational issues across the enterprise almost overnight. From this incident, NovaMart Global was able to understand that the required elements of cybersecurity resilience include:

- Persistent monitoring and detection mechanisms
- Swift coordination of incident response activities
- Robust access control and management functions
- Comprehensive business continuity planning
- Executive-level awareness of cyber risk
- Risk-driven, pro-active governance for security

The incident emphasized that it is critical to move from reactive operations to a pro-active, risk-driven approach to cybersecurity, that minimizes business and operational disruption.

11. Conclusion

This NovaMart Global ransomware incident was the first indication to how cyber events that are technical, rapidly progress into organizational, business risk events that have an enterprise-wide impact. This included multiple business-critical system outages, multiple operational impact areas and added enterprise-wide risk including:

- Financial (operational downtime, and loss)
- Reputational
- Compliance

Coordinated SOC investigation workflow, centralized SIEM monitoring and an integrated CSIRT were key elements which allowed the organization to successfully investigate, contain, and eradicate the ransomware outbreak before full operational and business-wide failure was achieved. This incident further highlighted that it is crucial to detect, proactively monitor, and respond to threats quickly in today's environment.

This incident proved the business risk correlation of security operations and its business risk.

Technical security operations directly impact:

- Operations and continuity
- Client confidence and reputation
- Regulatory and legal responsibilities
- Business continuity and strategic resilience
- The investigation identified opportunities for improvement, including:
- Security monitoring (using SIEM)
- Business threat intelligence data

Risk based analysis and correlation of technical security events and associated business risks

- Business continuity plans and drills
- Enterprise cyber risk management reporting to executive management
- Proactive security remediation and hardening efforts

Security enhancements including improved identity and access management, increased endpoint visibility, better phishing resistant culture, and greater threat detection capabilities were among many improvements identified and implemented in order to achieve greater resiliency against the Ransomware event.

This event demonstrated that effective cyber security can no longer be viewed as solely technical. Organizations are currently moving toward and can benefit from integrating cyber security operations within their broader security, operational risk, and enterprise governance initiatives by utilizing a risk-based approach to the entire cyber security operation.

This NovaMart Global ransomware incident was a case that has proved, that continued and sustained improvement of cyber security operations in terms of pro-activeness and organizational resiliency to the rapidly growing threat of ransomware has become paramount.